

Invariantes Estructurales y Matemática de Grafos de Ataque:

Una Plataforma Ofensiva–Defensiva Autónoma

Proyecto VALEN

Abstract—Presentamos Valen (*Verification And Active Logic Engine, Neuro-symbolic*), un sistema integral que une una tesis *defensiva* medida con una plataforma *ofensiva* sobre una única representación intermedia en grafo tipado ($\mathcal{G}$). En lo defensivo, zanjamos una pregunta de frontera con rigor estadístico: los invariantes espectrales, de homología (persistente y dirigida) y de curvatura discreta de los grafos de programa no aportan *información* más allá del taint para priorizar inyecciones (OWASP Benchmark 1.2, 2740 casos; taint MRR 0.894, AUC 0.895, campo fusionado 0.872, permutación pareada $p = 5 \times 10^{-5}$), aunque son la *única* señal para autorización (BOLA/IDOR: recall 1.0 / precisión 0.90 en crAPI), ciclos destructivos de estado (homología dirigida GLMY: 0.97 vs. 0.065 de recall frente a la simetrizada) y topología de confianza. En lo ofensivo, Valen es una plataforma de red teaming autónoma — un servidor multi-usuario que coordina reconocimiento, análisis de grafos de Active Directory, comando y control, recuperación de credenciales, phishing y exfiltración — cuyo diferencial es una *matemática de grafos de ataque* que enunciamos y probamos: cortes mínimos de Menger (puntos de estrangulamiento), flujo de costo mínimo, probabilidades de impacto de cadenas de Markov absorbentes resueltas exactamente por $(I - Q)^{-1}R$, síntesis de planes de explotación de costo mínimo mediante bounded model checking con Z3-Optimize (con precondiciones AND), y una gramática libre de contexto probabilística para adivinar contraseñas. El agente resuelve 18/18 retos documentados de crAPI de forma autónoma (incluidos tres retos de inyección de prompt sobre un LLM).

Index Terms—invariantes estructurales, análisis de taint, topología dirigida, grafos de ataque, red teaming autónomo, síntesis formal, adivinación de contraseñas

I. INTRODUCCIÓN

DOS preguntas organizan este trabajo. *Primera*, ¿dónde aportan los invariantes estructurales de los grafos de programa información de seguridad, y dónde no? *Segunda*, ¿puede la misma maquinaria convertirse en un motor de planificación cuantitativa para operaciones ofensivas? La respuesta a la primera es una frontera nítida y estadísticamente zanjada (§III-A); la respuesta a la segunda es una plataforma operativa cuyo diferencial es la matemática, no el scripting (§V, §VI).

Nuestras contribuciones son:

C1. Una *frontera medida* sobre los priors geométricos para SAST de inyección, con test de permutación pareado e intervalos de confianza bootstrap.

- C2.** Un *invariante de autorización operativo* mecanizado en Lean 4, un detector estructural de BOLA/IDOR y un testigo Z3 de propiedad que separa la autorización a nivel de objeto de la autenticación.
- C3.** Evidencia de que la *homología dirigida GLMY* es la señal correcta de ciclos, dominando a la homología simetrizada.
- C4.** Una *frontera de arbitraje neuro-simbólico* medida: el LLM propone, los métodos formales disponen.
- C5.** Un *front-end SAST multi-lenguaje*: un motor de taint genérico que conduce nueve gramáticas.
- C6.** Una *plataforma de red teaming autónoma* con un modelo de autorización primero.
- C7.** *Matemática de grafos de ataque* con pruebas: choke-points, planes de costo mínimo y disjuntos, probabilidades de impacto exactas, síntesis de explotación de costo mínimo y un prior PCFG de contraseñas.

II. MARCO FORMAL

Definición 1 (IR tipado). *Un grafo tipado es un multi-grafo dirigido $\mathcal{G} = (V, E, \tau_V, \tau_E, \alpha)$ donde $\tau_V : V \rightarrow \mathcal{K}_V$ etiqueta los vértices (módulo, función, sumidero, compuerta, principal, ...), $\tau_E : E \rightarrow \mathcal{K}_E$ etiqueta las aristas (control, dato, llamada, taint, confianza, autenticación, ...), y $\alpha : E \rightarrow \Sigma^*$ asocia atributos como un nombre de relación o un costo. Cada adaptador emite el mismo $\mathcal{G}$, de modo que todas las capas de análisis son agnósticas al motor.*

Definición 2 (Campo estructural). *Un campo estructural es una función $V(x) : \mathcal{G} \rightarrow \mathbb{R}^d$ que fusiona las señales algebraica (retículo de taint, nivel de privilegio), espectral (vector de Fiedler), topológica (H_0, H_1 persistentes y H_1 dirigida GLMY) y geométrica (curvatura de Forman–Ollivier Ricci) en una puntuación por nodo usada para priorizar.*

Definición 3 (Retículo de privilegios y arista de autenticación). *Sea $F : V \rightarrow \mathbb{N}$ un nivel de privilegio. Una arista $e = (u, v)$ con $\tau_E(e) = \text{auth}$ es una arista de autenticación si $F(u) < F(v)$. Un camino $\pi = v_0 \rightarrow \dots \rightarrow v_k$ es no vigilado (ungated) si ninguna de sus aristas es de autenticación.*

Proposición 1 (Sin escalada de privilegios sin aristas de autenticación). *Si $\pi = v_0 \rightarrow \dots \rightarrow v_k$ no está vigilado, entonces $F(v_k) \leq F(v_0)$.*

Proof. Toda arista no autenticada es intra-nivel o *descendente* en el retículo, es decir, para cada arista $e = (v_i, v_{i+1})$ de π se cumple $F(v_{i+1}) \leq F(v_i)$. Por transitividad $F(v_k) \leq F(v_0)$. El enunciado está mecanizado en Lean 4 como `no_auth_bounded`; la solidez de la abstracción booleana de taint es `prop1_soundness`. $\square$

Definición 4 (Grafo de ataque y costo). *Un grafo de ataque es un $\mathcal{G}$ cuyos vértices son principales y cuyas aristas $m \rightarrow n$ son acciones que requieren el control de m y producen el control de n . Un modelo de costo es $c : E \rightarrow \mathbb{R}_{>0}$ (sigilo más esfuerzo; p. ej. $c(\text{MemberOf}) = 1$, $c(\text{DCSync}) = 5$). Dado el conjunto de entrada S y el objetivo T , un plan de ataque es un conjunto de aristas cuyo cierre transitivo conecta algún $s \in S$ con algún $t \in T$.*

Definición 5 (Probabilidad de impacto). *Para un conjunto objetivo $T \subseteq V$, la probabilidad de impacto $h : V \rightarrow [0, 1]$ es*

$$h(u) = \begin{cases} 1 & u \in T, \\ \frac{1}{\deg^+(u)} \sum_{v: u \rightarrow v} h(v) & u \notin T, \end{cases}$$

la medida armónica de T bajo un paseo aleatorio uniforme sobre el grafo dirigido.

Proposición 2 (La probabilidad de impacto es la única solución armónica). *Para los nodos transitorios $u \notin T$, el vector h_T satisface $(I - Q)h_T = r$ donde Q es la matriz de transición transitorio-a-transitorio y $r_u = \sum_{v \in T} P_{uv}$; la solución es única y puede obtenerse por iteración de valor o por eliminación gaussiana en $O(|V|^3)$.*

Proof. Particionamos $V = T \uplus U$ (transitorio U). La ecuación de Bellman es $h_T = Qh_T + r$ con Q subestocástica (sumas de fila ≤ 1 , y < 1 para todo nodo con un vecino objetivo). Por tanto $I - Q$ es una M -matriz, luego no singular, y el punto fijo es único. La iteración de valor converge porque Q es una contracción en el subespacio transitorio. $\square$

III. VERIFICACIÓN ESTRUCTURAL

A. La frontera de los priors geométricos

Sobre OWASP Benchmark 1.2 [7] (2740 casos con veracidad de referencia conocida) un oráculo de priorización ordena todos los candidatos a sumidero y mide MRR, R@1, NDCG@k, más un test de permutación pareado e intervalos de confianza bootstrap.

Teorema 1 (Frontera, empírica). *Para fallas de inyección lineal, las señales geométricas/espectrales/topológicas no aportan información de priorización más allá del taint: el taint crudo logra MRR 0.894 (AUC 0.895); el campo estructural fusionado logra 0.872 ($p = 5 \times 10^{-5}$, IC 95% $[+0.0157, +0.0294]$); espectral (0.496) y topológica (0.500) están en el azar y la curvatura por debajo (0.376).*

Es un resultado negativo publicable: un servlet plano y casi acíclico no tiene curvatura ni topología persistente que explotar, y el taint ya es casi-óptimo allí. La Figura 1 muestra el AUC por señal.

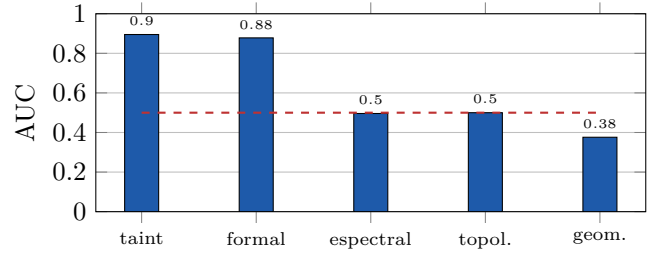


Fig. 1. La frontera: espectral y topológica en el azar, curvatura por debajo; el taint es la señal dominante.

B. Autorización, mecanizada y operativa

La Proposición 1 se operativiza en tres artefactos. (i) El detector estructural de *autorización ausente/BOLA* marca una función con fuente HTTP y sumidero de recurso sin compuerta de autenticación; sobre un corpus curado de 39 casos alcanza recall 1.0 / precisión 0.72 / F1 0.837 donde el taint puntúa 0. (ii) El verificador Z3 [6] comprueba $\text{SAT}(\text{owner}(id) \neq \text{session})$ — un testigo de propiedad que separa la autorización a nivel de objeto de la mera autenticación. (iii) En crAPI (44 operaciones, 9 endpoints BOLA/BFLA documentados) una señal de referencia a objeto recupera los 9 (recall 1.0, precisión 0.90).

C. Homología dirigida

Simetrizar un grafo dirigido es pérdida en ambos sentidos: un 2-ciclo $A \rightarrow B \rightarrow A$ colapsa a una arista no dirigida (una reentrancia perdida) y un triángulo relleno se vuelve un falso ciclo.

Proposición 3 (Homología dirigida vs. simetrizada). *La homología dirigida GLMY H_1 [3] es un superconjunto estricto de la simetrizada para detectar ciclos destructivos: recall 1.0 / precisión 0.75 sobre un corpus de 12 grafos de estado (vs. 0.5/0.5) y 0.968 vs. 0.065 sobre contratos inteligentes curados de SmartBugs.*

D. Arbitraje neuro-simbólico

Sobre un corpus de 38 archivos (29 hallazgos confirmados) la heurística offline y el agente LiteLLM coinciden en detección y ranking en 37/38 archivos (acuerdo 0.974), mientras el LLM cambia el CWE en 28% de los hallazgos.

IV. SAST MULTI-LENGUAJE

Un motor de taint genérico conduce nueve gramáticas tree-sitter (C, C++, Rust, C#, Go, PHP, Ruby, JavaScript/TypeScript) con perfiles por lenguaje que declaran fuentes, sumideros, sanitizadores y compuertas de autenticación; Python, Java (interprocedural) y Solidity tienen adaptadores dedicados.

V. LA PLATAFORMA DE RED TEAMING

VALEN es un paquete instalable cuyo servidor es un *servidor de equipo* multi-usuario: usuarios con roles (`viewer/operator/admin`), sesiones PBKDF2, RBAC

por ruta, compromisos con membresía, artefactos de evidencia y Server-Sent Events para colaboración en vivo. La superficie recorre la cadena de destrucción (kill chain) y está limitada por una lista de alcance, una lista de ejecución (`-allow-exec`) y la aprobación del operador.

VI. MATEMÁTICA DE GRAFOS DE ATAQUE

A. Chokepoints vía corte mínimo de Menger

Teorema 2 (Menger, forma vértice). *El número máximo de caminos internamente disjuntos de S a T es igual al número mínimo de vértices cuya remoción separa S de T [4].*

Construcción. Dividimos cada v en $v_{in} \rightarrow v_{out}$ de capacidad 1 (ilimitada para $v \in S \cup T$), reemplazamos cada $u \rightarrow v$ por $u_{out} \rightarrow v_{in}$ de capacidad ∞ , y añadimos una superfuente a S y T a un super-sumidero. Un flujo máximo satura las aristas de división unitarias de un corte mínimo de vértices (Ford–Fulkerson [5]). $\square$

B. Flujo de costo mínimo

Enviar k unidades de flujo a costo mínimo, con vértices internos de capacidad 1, produce las k rutas de ataque *más baratas y disjuntas*. Implementamos caminos de aumento sucesivos de costo mínimo (Bellman–Ford sobre el grafo residual).

C. Probabilidad de impacto

La Proposición 2 da el ranking de riesgo probabilístico; en el corpus de juguete una entrada con tres aristas salientes y una ruta al objetivo puntúa $\frac{1}{3}$, una entrada directa 1.

D. Síntesis formal: planes de explotación de costo mínimo

Teorema 3 (Solidez y optimalidad de la síntesis). *Sea el sistema de transición*

$$\text{has}(s+1, n) \equiv \text{has}(s, n) \vee \bigvee_{e: m \rightarrow n} (\text{taken}_e \wedge \text{has}(s, m)),$$

*con entradas en el paso 0. Una asignación satisfacible de **z3.Optimize** [6] que minimiza $\sum_e \text{taken}_e c(e)$ bajo $\bigvee_{s \leq k} \text{has}(s, t)$ es (i) un plan factible y (ii) de costo mínimo entre los planes de longitud $\leq k$.*

Proof. (i) Se sigue por inducción sobre el índice de paso: **has** es monótona y cada arista **taken** tiene su fuente verdadera en el paso en que se dispara. (ii) El objetivo es exactamente el costo del plan y el optimizador devuelve un mínimo sobre el espacio de búsqueda acotado. Las acciones compuestas $\{\text{sources} \rightarrow \text{target}\}$ añaden $\bigwedge_s \text{has}(s)$ como precondition AND, p. ej. DCSync requiere Domain Admins y una sesión en un Domain Controller. $\square$

Contribución	Resultado
C1 frontera	taint 0.894 vs. campo 0.872
C2 autorización	BOLA 1.0 / 0.90
C3 homología dirigida	0.97 vs. 0.065 recall
C4 arbitraje	acuerdo 0.974; CWE 28%
C5 lenguajes	9 lenguajes, 1 motor
C7 matemática	chokepoints, flujo, síntesis, PCFG
Red team	crAPI 18/18 resuelto
Calidad	383 tests, instalable, Docker

TABLE I
RESUMEN DE RESULTADOS MEDIDOS.

E. Adivinación de contraseñas: PCFG

Definición 6 (PCFG). *Tokenizamos una contraseña en tramos de letras L , dígitos D , símbolos S . Una estructura base es la secuencia de pares (clase, longitud) (p. ej. $L_6 D_4 S_1$); los terminales se indexan por (clase, longitud). La probabilidad de una adivinanza σ es $P(\sigma) = P(\text{structure}) \cdot \prod_{t \in \sigma} P(t)$ [1].*

Proposición 4 (Enumeración monótona). *La expansión best-first sobre los terminales por ranura, ordenada por probabilidad decreciente, enumera adivinanzas en $P(\sigma)$ no creciente y sin duplicados.*

Proof. La log-probabilidad negativa $-\log P(\sigma)$ es un costo aditivo no negativo por ranura, de modo que Dijkstra sobre el retículo producto visita las adivinanzas en costo no decreciente; el conjunto *seen* evita la re-expansión. $\square$

VII. EVALUACIÓN

A. Pentest autónomo contra OWASP crAPI

Contra un laboratorio crAPI 1.1.5 fresco el agente autónomo resuelve **18/18** retos documentados — BOLA/BFLA, asignación masiva, SSRF, inyección NoSQL/SQL, falsificación JWT, reseteo de contraseña, límite de tasa y tres retos de inyección de prompt sobre un LLM. El detector BOLA alcanza recall 1.0 / precisión 0.90 / F1 0.947.

B. Resultados de un vistazo

VIII. LIMITACIONES Y ÉTICA

Las evaluaciones son una API real más corpora curados, no benchmarks públicos; el detector estructural sobreaproxima; el testigo Z3 vale bajo la semántica *modelada*; el fallback numérico pure-Python aproxima el núcleo Rust; el prior PCFG es tan bueno como su corpus. La plataforma es una herramienta de compromiso autorizado: el alcance es loopback por defecto, la ejecución está tras `-allow-exec` y las acciones intrusivas requieren aprobación del operador.

IX. CONCLUSIÓN

VALEN aporta una frontera falsable, un invariante de autorización mecanizado, la señal de ciclo correcta, una frontera de arbitraje neuro-simbólico medida, un front-end multi-lenguaje, una plataforma de red teaming autónoma y una matemática de grafos de ataque probada. Un IR tipado une lo defensivo y lo ofensivo, y todo resultado lleva un testigo verificable por máquina.

REFERENCES

- [1] M. Weir, S. Aggarwal, B. de Medeiros, and B. Glodek, “Password cracking using probabilistic context-free grammars,” *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2009.
- [2] J. Ma, W. Yang, M. Luo, and N. Li, “A study of probabilistic password models,” *Proc. IEEE S&P*, 2014.
- [3] A. Grigor’yan, Y. Lin, Y. Muranov, and S.-T. Yau, “Homologies of path complexes and digraphs,” arXiv:1207.2834, 2012.
- [4] K. Menger, “Zur allgemeinen Kurventheorie,” *Fundamenta Mathematicae*, vol. 10, pp. 96–115, 1927.
- [5] L. R. Ford and D. R. Fulkerson, “Maximal flow through a network,” *Canadian Journal of Mathematics*, vol. 8, pp. 399–404, 1956.
- [6] L. de Moura and N. Bjørner, “Z3: An efficient SMT solver,” *Proc. TACAS*, 2008.
- [7] OWASP, “OWASP Benchmark Project,” <https://owasp.org/www-project-benchmark/>, 2015.
- [8] MITRE, “ATT&CK for Enterprise,” <https://attack.mitre.org/>, 2023.
- [9] FIRST, “CVSS v3.1 Specification Document,” <https://www.first.org/cvss/v3.1/specification-document>, 2019.
- [10] OWASP, “crAPI — Completely Ridiculous API,” <https://owasp.org/www-project-crapi/>.
- [11] L. de Moura and S. Ullrich, “The Lean 4 theorem prover and programming language,” *Proc. CADE*, 2021.